

RECONNAISSANCE & NETWORK ENUMERATION

Attack Surface Summary

Target: 192.168.1.3 (Metasploitable 2)

Scanner: Kali Linux 192.168.1.4

Attack Surface Overview

The attack surface of a system refers to the sum of its different points (the "attack vectors") where an unauthorized user can try to enter data to or extract data from an environment. Based on the network reconnaissance and service enumeration, the target system (192.168.1.3) presents an exceptionally large attack surface. With 13 open TCP ports spanning a wide variety of technologies, the system is exposed to multiple categories of potential threats.

Categorized Exposures and Their Implications

- **Remote Access & Administration**

Exposed Services: SSH (22), Telnet (23), VNC (5900), Rlogin/Rsh (512, 513, 514).

Why it matters: These services provide direct pathways to system-level command execution. Telnet and R-services transmit data, including credentials, in plain text, making them highly susceptible to network sniffing. While SSH and VNC offer better security, older versions or weak passwords can be subjected to brute-force attacks or known exploits.

- **File Sharing & Storage**

Exposed Services: FTP (21), SMB (139, 445), NFS (2049).

Why it matters: File-sharing protocols are designed to distribute data, which inherently risks unauthorized data disclosure. The enumeration revealed that anonymous FTP login is permitted and SMB message signing is disabled. This lack of access control and encryption can allow attackers to steal sensitive files, upload malicious payloads, or perform man-in-the-middle (MitM) attacks.

- **Web & Application Infrastructure**

Exposed Services: HTTP (80), Tomcat (8180), Java RMI (1099), AJP13 (8009).

Why it matters: Web and application servers are frequently targeted because they host complex, public-facing applications. The presence of older software versions (like Apache 2.2.8 and Tomcat 5.5) introduces a high probability of unpatched, critical vulnerabilities (such as Remote Code Execution or Directory Traversal) that attackers can exploit to gain a foothold on the server.

- **Databases**

Exposed Services: MySQL (3306), PostgreSQL (5432).

Why it matters: Databases hold a system's most valuable information. Exposing them directly to the network, rather than restricting access to backend application servers, drastically increases the risk of data breaches, SQL injection exploits, and brute-force credential attacks directly against the database engines.

- **Infrastructure & Miscellaneous Services**

Exposed Services: DNS (53), SMTP (25), RPC (111), IRC (6667).

Why it matters: These supporting services can leak extensive information about the internal network (e.g., DNS zone transfers). Additionally, an unsecured SMTP server can be used as an open relay for spam, while an exposed IRC daemon could potentially be compromised or utilized as part of a command-and-control (C2) botnet infrastructure.

Summary Table of Critical Exposures

Risk Category	Exposed Ports	Primary Security Implication
Plaintext Authentication	21 (FTP), 23 (Telnet)	Credentials can be intercepted via packet sniffing.
Legacy/Insecure Protocols	512, 513, 514 (Rservices)	Unauthenticated command execution; lack of encryption.

Misconfigured Access	139/445 (SMB), 2049 (NFS)	Unauthorized access to shared network files and resources.
Outdated Web Technologies	80 (HTTP), 8180 (Tomcat)	Susceptible to known Remote Code Execution (RCE) flaws.
Direct Database Access	3306 (MySQL), 5432 (Postgres)	Bypasses application security tiers; high risk of data exfiltration.

Conclusion

The extensive list of exposed services significantly expands the attack surface of the target system. In a real-world enterprise environment, such an exposure profile would violate the principle of least privilege and zero-trust architecture. To secure a system like this, administrators must apply defense-in-depth strategies: disabling unnecessary services, implementing strict firewall filtering, updating all software to supported versions, and enforcing secure, encrypted authentication mechanisms across all remaining interfaces.